# Cyber Crime Case Studies

Six Real-World Incidents

Name: **Raval Kirtan**
Enrollment Number: **241105060113**

# Index


| No. | Case |
|---|---|
| 1 | Sony Pictures Entertainment Hack (USA, 2014) |
| 2 | Capital One Data Breach (USA, 2019) |
| 3 | Mirai Botnet and the Dyn DDoS Attack (Global, 2016) |
| 4 | SolarWinds Supply Chain Attack (USA / Global, 2020) |
| 5 | Ashley Madison Data Breach (Canada / Global, 2015) |
| 6 | AIIMS Delhi Ransomware Attack (India, 2022) |

# Case 1: Sony Pictures Entertainment Hack (USA, 2014)

### 1. What happened

On 24 November 2014 a group calling itself Guardians of Peace took over Sony Pictures' computers, displayed a warning on screens and later leaked unreleased films, employee personal data including Social Security numbers, and internal emails. Many company computers were rendered unusable.

### 2. Attack technique

The attackers used destructive wiper malware that erased data on infected machines. The method of first entry was not publicly confirmed; reports mention stolen credentials and possible phishing.

### 3. Loss and impact

Employees' personal data and private emails became public, and several unreleased films were leaked. Sony reported about US$15 million in investigation and remediation costs in its early reporting, and later lawsuits by employees were settled.

### 4. Response and recovery

The FBI investigated and in December 2014 stated that the US government attributed the attack to North Korea. Sony rebuilt its network, offered identity-protection services to employees and restored operations over several weeks.

### 5. How it could have been prevented

Segment internal networks, keep offline backups, limit administrator privileges, monitor for mass file deletion and rehearse an incident response plan.

### 6. Key lesson

Destructive attacks can stop a business as well as steal data, so backup and response planning matter as much as prevention.

*Sources: FBI statement (19 December 2014); Sony Corporation financial reports (2015). Figures are approximate.*

# Case 2: Capital One Data Breach (USA, 2019)

### 1. What happened

Between March and July 2019 an attacker accessed data stored in the cloud by Capital One. The company announced the breach on 29 July 2019 after receiving a tip. About 100 million people in the US and 6 million in Canada were affected.

### 2. Attack technique

The attacker, a former cloud-company engineer, exploited a misconfigured web application firewall using a server-side request forgery (SSRF) attack. This let her obtain temporary credentials and then read data from cloud storage.

### 3. Loss and impact

Stolen data included credit-application details for many people, about 140,000 Social Security numbers and about 80,000 linked bank account numbers. Capital One estimated costs of up to US$150 million in 2019, and later paid an US$80 million penalty (2020) and a US$190 million class-action settlement (2022).

### 4. Response and recovery

Capital One fixed the misconfiguration, notified affected customers and offered free credit monitoring. The attacker was arrested in July 2019 and was convicted in 2022 of wire fraud and unauthorised access.

### 5. How it could have been prevented

Review cloud configurations regularly, apply least-privilege roles, restrict metadata-service access, encrypt or tokenise sensitive fields and monitor unusual data downloads.

### 6. Key lesson

Moving to the cloud does not remove responsibility. A single misconfiguration can expose millions of records.

*Sources: US Department of Justice (2019, 2022); US Office of the Comptroller of the Currency (2020). Figures are approximate.*

# Case 3: Mirai Botnet and the Dyn DDoS Attack (Global, 2016)

### 1. What happened

On 21 October 2016 a distributed denial-of-service (DDoS) attack on the DNS provider Dyn made many popular websites, including Twitter, Netflix, Reddit and PayPal, unreachable for many users for several hours.

### 2. Attack technique

The attack used the Mirai botnet, made of hundreds of thousands of internet-connected devices such as cameras and routers. Mirai found devices that still used factory-default usernames and passwords, took control of them and used them to flood Dyn with traffic. The traffic was reported to be around 1 terabit per second.

### 3. Loss and impact

Users in North America and Europe could not reach many major services. Dyn lost customers after the incident. A single total financial loss figure is not established.

### 4. Response and recovery

Dyn and its partners mitigated the traffic and restored service the same day. The US FBI investigated, and in 2017 the young creators of Mirai pleaded guilty to charges related to the botnet.

### 5. How it could have been prevented

Change default passwords on devices; require manufacturers to ship unique credentials; update firmware; use several DNS providers; and use DDoS protection services.

### 6. Key lesson

Insecure everyday devices can be turned into weapons, and depending on a single provider is a risk.

*Sources: Dyn public analysis (October 2016); US Department of Justice (2017). Figures are approximate.*

# Case 4: SolarWinds Supply Chain Attack (USA / Global, 2020)

### 1. What happened

In December 2020 the security company FireEye reported it had been breached and traced the intrusion to a poisoned software update for SolarWinds' Orion network-management product. The update had been distributed from about March 2020.

### 2. Attack technique

Attackers secretly inserted a backdoor, later named SUNBURST, into the software build process. About 18,000 customers installed the update, and the attackers then chose a smaller number of targets, reported at around 100 organisations and several US government agencies, for further spying.

### 3. Loss and impact

The attack mainly involved espionage, and the quantity of stolen information is not fully known. Costs for affected organisations included investigations and rebuilding trust in their software. Total cost has not been established.

### 4. Response and recovery

Customers disconnected or updated Orion and hunted for intruders. In April 2021 the US government formally attributed the operation to Russia's foreign intelligence service (SVR) and announced sanctions. Governments issued new supply-chain security requirements.

### 5. How it could have been prevented

Secure and monitor software build systems; verify software signing; limit privileges of management tools; segment networks; keep a software bill of materials; and watch outbound traffic.

### 6. Key lesson

You can be compromised through trusted software, so even updates need verification and monitoring.

*Sources: US CISA emergency directive 21-01 (2020); US White House statement (April 2021). Figures are approximate.*

# Case 5: Ashley Madison Data Breach (Canada / Global, 2015)

### 1. What happened

In July 2015 a group calling itself the Impact Team announced it had stolen data from Avid Life Media, the company behind the Ashley Madison dating website, and in August 2015 published it online. Records for around 32 to 37 million accounts were reported to be exposed.

### 2. Attack technique

The attackers gained access to the company's systems and copied databases, including user profiles, email addresses and payment records. Later investigations by privacy regulators found weaknesses such as poor security governance and weak protection of some passwords.

### 3. Loss and impact

Exposed users faced blackmail attempts, public embarrassment and reputational harm, and some cases of serious personal consequences were reported. The company faced lawsuits and regulatory action, including an US$11.2 million class-action settlement and a US$1.66 million settlement with US regulators (partly suspended).

### 4. Response and recovery

The company's leadership changed and the company was reorganised. Canadian and Australian privacy commissioners issued a joint report in 2016, and the company agreed to improve its security programme.

### 5. How it could have been prevented

Adopt a documented security programme, use strong password hashing, encrypt sensitive data, delete data when promised, and conduct independent security audits.

### 6. Key lesson

Collecting sensitive data creates a duty to protect it, and promises such as 'full delete' must be real.

*Sources: Office of the Privacy Commissioner of Canada and Australian Information Commissioner (2016); US FTC (2016). Figures are approximate.*

# Case 6: AIIMS Delhi Ransomware Attack (India, 2022)

### 1. What happened

On 23 November 2022 the servers of the All India Institute of Medical Sciences, Delhi, were hit by a ransomware attack. Online services such as patient registration, billing, appointments and lab reports stopped, and the hospital moved to manual paper-based work.

### 2. Attack technique

Ransomware encrypted data on the hospital's servers. The exact entry method was not publicly confirmed. Media reports mentioned a large ransom demand in cryptocurrency, but officials did not confirm the amount.

### 3. Loss and impact

Patient care was disrupted, with long queues and delays. The data of a very large number of patients was reportedly at risk. A confirmed financial loss figure has not been published.

### 4. Response and recovery

Agencies including the Delhi Police, CERT-In and other government cyber teams investigated. Servers were cleaned and rebuilt, and digital services returned in stages over about two weeks. Government agencies reviewed security at other health institutions.

### 5. How it could have been prevented

Keep offline backups, separate hospital networks, update and patch systems, require multi-factor authentication, train staff against phishing and prepare manual fallback procedures.

### 6. Key lesson

Hospitals are critical services, so security failures can directly affect patient care.

*Sources: Indian press reports and government statements (November-December 2022). Some details are as reported and not independently verified.*